

ADR-003: Auth.js (v5) mit datenbankgestützten Sessions

Status: Akzeptiert

Datum: 31.08.2026

Entscheider: Architektur-Team PraxisFlow AI

Kontext

PraxisFlow verarbeitet Gesundheitsdaten. Die Authentifizierungslösung muss:

- Sessions sofort widerrufbar machen (nicht stateless JWT)
- HttpOnly-Cookies verwenden (kein localStorage für Tokens)
- RBAC auf dem Server integrieren
- MFA vorbereiten
- Portabel sein (kein Vendor-Lock-in)

Entscheidung

Auth.js v5 (stable) mit datenbankgestützten Sessions via Prisma-Adapter. Kein reines JWT ohne serverseitige Invalidierungsmöglichkeit.

Begründung

- **Widerrufbarkeit:** Sessions in der Datenbank können sofort invalidiert werden
- **HttpOnly-Cookies:** Kein Token im Browser-Speicher, kein XSS-Risiko
- **Prisma-Adapter:** Native Integration mit bestehendem Datenbankschema
- **MFA-Vorbereitung:** Auth.js unterstützt TOTP-Flow
- **RBAC:** Session enthält Benutzer-ID; Rollen werden serverseitig geladen

Warum kein reines stateless JWT?

Stateless JWT können nicht widerrufen werden. Bei einem kompromittierten Account müsste man warten, bis das Token abläuft. Im Gesundheitskontext ist sofortiger Widerruf zwingend.

Nachteile (akzeptiert)

- Session-Lookup bei jedem Request (mitigiert durch PostgreSQL-Index auf Session-Token)
- Auth.js v5 ist noch relativ neu (mitigiert durch Abstraktion via eigene Auth-Schicht)

Alternativen verworfen

- **Stateless JWT (z.B. Jose):** Kein sofortiger Widerruf möglich
- **Lucia Auth:** Gute Alternative, aber kleinere Community
- **Keycloak:** Zu komplex für Pilot; als Option für Produktion dokumentiert